

OPERATION BLACK FORGE — RISK REGISTER

CTF 2 | CIP-A105 | Daniyal Ahmed — C11/26/EHIT/17331 | Training Use Only

FIND-01 Insecure Directory Listing and Information Disclosure MEDIUM Risk Score: 30/100			
Asset / Service	Likelihood: 6/10	Impact: 5/10	Evidence: E-009, E-011, E-012
Technical Description: Apache has directory listing enabled and robots.txt discloses internal paths including /openemr/, /gitweb/, /doc/, and /vendor/. This reveals application structure and version information to unauthenticated attackers.			
Recommended Controls: Disable Options Indexes in httpd.conf. Sanitise robots.txt to remove sensitive internal path references. Implement a security baseline review for all Apache virtual host configurations.			

FIND-02 OpenEMR 4.1.0 SQL Injection — EDB-49742 CRITICAL Risk Score: 100/100			
Asset / Service	Likelihood: 10/10	Impact: 10/10	Evidence: E-013 through E-022
Technical Description: The OpenEMR 4.1.0 login endpoint accepts unsanitised user input via the 'u' GET parameter and passes it directly to an SQL query. Using sqlmap with boolean-based blind injection, the complete openemr database was extracted including all user credentials.			
Recommended Controls: Upgrade OpenEMR to the latest patched version. Implement parameterised queries throughout the application. Deploy a WAF with SQLi detection rules. Conduct regular application security assessments.			

FIND-03 Weak Application Credentials and Legacy MD5 Password Hashing HIGH Risk Score: 81/100			
Asset / Service	Likelihood: 9/10	Impact: 9/10	Evidence: E-023, E-024
Technical Description: The OpenEMR administrator account used a trivially guessable password ([REDACTED]) stored as an unsalted MD5 hash. The hash was cracked immediately using an online service. A second account (medical) used its own username as the password. Both represent severe credential hygiene failures.			
Recommended Controls: Enforce a strong password policy (minimum 12 characters, mixed case, digits, symbols). Migrate from MD5 to bcrypt or Argon2id for all password storage. Implement account lockout after failed login attempts.			

FIND-04 | Authenticated Arbitrary PHP File Edit via Admin Panel | CRITICAL | Risk Score: 90/100

Asset / Service	Likelihood: 9/10	Impact: 10/10	Evidence: E-025, E-026, E-027, E-028
-----------------	------------------	---------------	--------------------------------------

Technical Description: The OpenEMR admin panel provides a built-in file editor allowing authenticated administrators to directly modify server-side PHP files including config.php. After authenticating with stolen credentials, a PHP reverse shell payload was injected. When the application loaded the modified file, a shell was returned as the apache web server user.

Recommended Controls: Remove or permanently disable the Administration > Files editor feature. Apply read-only file permissions to all PHP application files at the OS level. Implement file integrity monitoring (e.g., AIDE, Tripwire) to detect unauthorised file modifications.

FIND-05 | SUID Binary PATH Hijacking — Privilege Escalation to Root | CRITICAL | Risk Score: 80/100

Asset / Service	Likelihood: 8/10	Impact: 10/10	Evidence: E-029, E-030
-----------------	------------------	---------------	------------------------

Technical Description: A SUID root binary was identified that calls an external system command without using an absolute path. By placing a malicious script with the same name as the called command in /tmp and prepending /tmp to the PATH environment variable, the SUID binary was tricked into executing attacker-controlled code with root privileges, yielding a root shell.

Recommended Controls: Audit all SUID/SGID binaries: find / -perm -4000 -type f. Remove SUID bits from all binaries that do not strictly require them. Ensure all SUID binaries use absolute paths for any external command calls. Implement regular SUID auditing as part of the hardening process.

FIND-06 | ProFTPD 1.3.3d — Significantly Outdated Service | HIGH | Risk Score: 56/100

Asset / Service	Likelihood: 7/10	Impact: 8/10	Evidence: E-007
-----------------	------------------	--------------	-----------------

Technical Description: ProFTPD version 1.3.3d is significantly outdated and has multiple known CVEs including remote code execution vulnerabilities. While not directly exploited in this engagement (FTP credentials were not obtained), the service represents a significant unmitigated attack surface.

Recommended Controls: If FTP functionality is required, upgrade ProFTPD to the latest stable release immediately. Evaluate replacing FTP with SFTP (OpenSSH) for encrypted file transfer. If FTP is not operationally required, disable and remove the service.

Risk Summary

ID	Finding	Likelihood	Impact	Risk Score
FIND-01	Insecure Directory Listing and Information Disclosure	6	5	30
FIND-02	OpenEMR 4.1.0 SQL Injection — EDB-49742	10	10	100
FIND-03	Weak Application Credentials and Legacy MD5 Password Hashing	9	9	81
FIND-04	Authenticated Arbitrary PHP File Edit via Admin Panel	9	10	90
FIND-05	SUID Binary PATH Hijacking — Privilege Escalation to Root	8	10	80
FIND-06	ProFTPD 1.3.3d — Significantly Outdated Service	7	8	56

Note: Risk Score = Likelihood (1–10) × Impact (1–10). Critical ≥ 80 | High ≥ 40 | Medium ≥ 15 | Low < 15. Classification: Training Use Only | Author: Daniyal Ahmed | C11/26/EHIT/17331